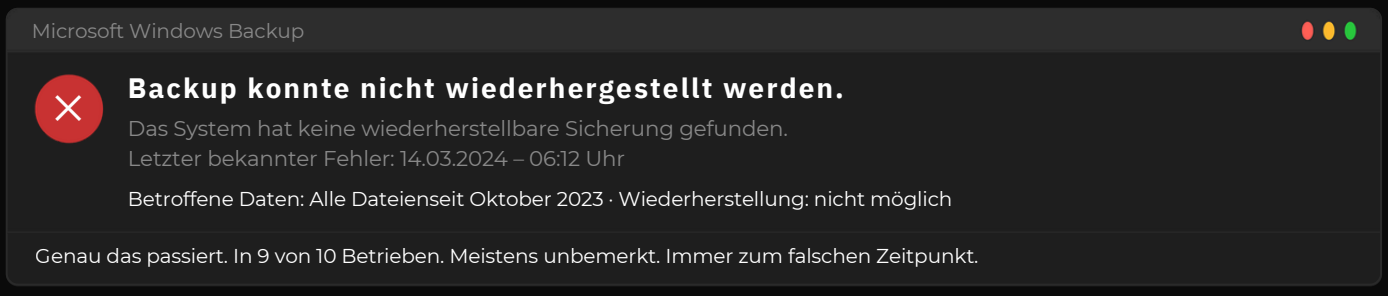
Blaschke IT

IT-SICHERHEIT FÜR DEN MITTELSTAND

DER KOSTENLOSE SICHERHEITSLEITFADEN

Die 10 größten IT-Sicherheitslücken in deutschen KMUs.

Und wie du sie erkennst – bevor jemand anderes sie findet.



Genau das passiert. In 9 von 10 Betrieben. Meistens unbemerkt. Immer zum falschen Zeitpunkt.

9/10	197	500€
Betriebe haben mindestens eine kritische Lücke	Tage bleiben Hacker im Schnitt unbemerkt im Netzwerk	Wert des kostenlosen Security-Checks von Blaschke IT

Kostenloser Security-Check für Unternehmen

100% kostenlos · Für Unternehmen ab 10 Mitarbeitern · Kein Vertrag · anfrage.blaschke.cloud/security

VORWORT

Warum ich diesen Leitfaden geschrieben habe.



Lukas Blaschke
Inhaber · Blaschke IT, Haan

Ich bin seit über 20 Jahren in der IT. Und ich kann dir eines sagen:

Ich habe noch nie einen Betrieb ohne Befund gesehen.

Nicht, weil die Geschäftsführer schlampen. Sondern weil IT-Sicherheit das Erste ist, das im Alltag untergeht. Man kümmert sich ums Tagesgeschäft, um Kunden, um Mitarbeiter – und die IT läuft. Irgendwie. Bis sie es nicht mehr tut.

Die 10 Lücken in diesem Leitfaden sind keine Theorie. Das sind die Dinge, die wir wöchentlich in echten Betrieben finden – oft, ohne dass jemand es wusste. Manchmal seit Jahren.

Du brauchst dafür keinen IT-Experten. Nur 20 Minuten und die Bereitschaft, hinzuschauen. Für jede Lücke gibt es eine konkrete Checkliste, was du diese Woche tun kannst.

– Lukas Blaschke, Inhaber Blaschke IT

LÜCKE 01 · HÄUFIGSTER BEFUND

Das Backup, das nie getestet wurde

01

DAS PROBLEM

Dein Backup läuft täglich – aber hast du es je wirklich wiederhergestellt? Die meisten Betriebe merken erst beim Ernstfall, dass ihr Backup seit Wochen stillschweigend fehlschlägt. Und selbst wenn es läuft: Ein Backup auf demselben System ist wertlos. Ransomware löscht es als Erstes.

DAS RISIKO

Selbst ein funktionierendes Backup kann wertlos sein – wenn es auf demselben System liegt das angegriffen wird. Ransomware sucht als erstes nach Backups, um sie zu verschlüsseln oder zu löschen. Ein Backup auf demselben Windows-Server, das es sichert, ist kein Backup. Es ist eine zweite Kopie, die gleichzeitig verloren geht.

Das Backup lief. Auf demselben Server. Als wir gehackt wurden, war beides weg – **die Daten und die Sicherung**. *Gleichzeitig.*

WAS DU DIESE WOCHE TUN KANNST

- ☐ Läuft das Backup auf einem separaten System? (nicht auf demselben Server/Betriebssystem)
- ☐ Backup-Log der letzten 30 Tage prüfen – gibt es Fehlermeldungen?
- ☐ Testwiederherstellung einer wichtigen Datei oder Datenbank durchführen
- ☐ Backup-Aufbewahrungszeit prüfen – wie weit geht die Historie zurück?
- ☐ Offsite-Backup vorhanden? (nicht nur lokale Sicherung)

LÜCKE 02 · KRITISCHES SICHERHEITSRISIKO

Offene Zugänge von Ex-Mitarbeitern

02

DAS PROBLEM

Wenn ein Mitarbeiter das Unternehmen verlässt – werden seine Zugänge zu E-Mail, Cloud, Buchhaltungssoftware und internen Systemen sofort deaktiviert? In den meisten Betrieben: nein. Der Zugangsentzug läuft hinterher oder wird einfach vergessen.

DAS RISIKO

Ein unzufriedener Ex-Mitarbeiter – oder ein Hacker, der dessen Daten erbeutet hat – kann sich **monatelang unbemerkt Zugang verschaffen**, Daten kopieren, löschen oder manipulieren.

„Wir haben **drei aktive Zugänge** *gefunden – von Mitarbeitern die seit über einem Jahr nicht mehr im Unternehmen waren."*

WAS DU DIESE WOCHE TUN KANNST

- ☐ Alle aktiven E-Mail-Konten auflisten und mit aktueller Mitarbeiterliste abgleichen
- ☐ Cloud-Dienste (Google, Microsoft, Dropbox) auf aktive Nutzer prüfen
- ☐ VPN- und Remote-Zugänge auf veraltete Accounts überprüfen
- ☐ Offboarding-Checkliste für zukünftige Mitarbeiterabgänge erstellen

LÜCKE 03 · RECHTLICHES RISIKO

Daten auf US-Servern – der Patriot Act

03

DAS PROBLEM

Microsoft 365, Google Workspace, Dropbox – alle US-Unternehmen sind per Patriot Act und CLOUD Act gesetzlich verpflichtet, US-Behörden Zugang zu deinen Daten zu gewähren. Egal wo die Server physisch stehen. Egal was in deinem Vertrag steht.

DAS RISIKO

Deine Kundendaten, Verträge, Patente und interne Kommunikation können **ohne dein Wissen und ohne Vorwarnung eingesehen werden**. Für Unternehmen mit sensiblen Geschäftsgeheimnissen ein massives Risiko.

„**Der Patriot Act ist kein Einzelfall** – *er ist gültiges US-Recht. Und er gilt für jeden der Microsoft oder Google nutzt."*

WAS DU DIESE WOCHE TUN KANNST

- ☐ Alle genutzten Cloud-Dienste und deren Serverstandorte auflisten
- ☐ Prüfen ob DSGVO-konforme Alternativen mit deutschen Servern verfügbar sind
- ☐ Kundendaten auf US-Servern? – Datenschutzbeauftragten einschalten
- ☐ Hosting-Verträge auf Datensicherheitsklauseln prüfen lassen

LÜCKE 04 · HÄUFIG AUSGENUTZT

Veraltete Software als offenes Einfallstor

04

DAS PROBLEM

Jedes ungepatchte System ist ein offenes Fenster für Angreifer. Bekannte Sicherheitslücken werden innerhalb von Stunden nach Bekanntwerden aktiv ausgenutzt – von automatisierten Werkzeugen die das gesamte Internet kontinuierlich scannen.

DAS RISIKO

60% aller Cyberangriffe nutzen bekannte Sicherheitslücken aus – für die es längst Updates gibt. Ransomware, Datenverlust, Betriebsausfall. Es ist keine Frage des Ob, sondern des Wann.

„Die Firewall war vorhanden und aktiv. Aber das letzte **Firmware-Update war von 2021.**"

WAS DU DIESE WOCHE TUN KANNST

- ☐ Windows/macOS automatische Updates auf allen Geräten aktivieren
- ☐ Browser, VPN-Software und Office-Pakete auf aktuelle Versionen prüfen
- ☐ Router und Firewall Firmware-Version prüfen und aktualisieren
- ☐ Veraltete Software die nicht mehr gepflegt wird identifizieren und ersetzen

LÜCKE 05 · EINSTIEGSTOR NR. 1

Schwache oder geteilte Passwörter

05

DAS PROBLEM

„Sommer2024!", das Geburtsdatum des Chefs, oder ein Passwort, das alle Mitarbeiter kennen – das sind keine Ausnahmen. Das ist Alltag. Schwache Passwörter sind der häufigste Einstiegspunkt für Cyberangriffe weltweit.

DAS RISIKO

Schwache Passwörter werden von modernen Tools **in Sekunden geknackt**. Geteilte Passwörter bedeuten: Wenn einer geht, hat er noch Zugang. Wenn einer auf Phishing hereinfällt, ist das ganze Netzwerk offen.

„Das **Admin-Passwort für den Server** *stand auf einem Post-it am Monitor. Seit Jahren."*

WAS DU DIESE WOCHE TUN KANNST

- ☐ Passwortmanager einführen (z.B. Bitwarden – kostenlos verfügbar)
- ☐ Zwei-Faktor-Authentifizierung für E-Mail und Cloud aktivieren
- ☐ Geteilte Passwörter identifizieren und individuell vergeben
- ☐ Passwort-Mindestanforderungen schriftlich festlegen und kommunizieren

LÜCKE 06 · GRUNDSCHUTZ FEHLT

Kein Virenschutz auf allen Geräten

06

DAS PROBLEM

Viele Betriebe haben Virenschutz auf den Büro-PCs – aber was ist mit den Laptops der Mitarbeiter? Den Home-Office-Geräten? Den Tablets? Jedes ungeschützte Gerät, das sich ins Firmennetzwerk einloggt, ist ein potenzieller Eintrittspunkt.

DAS RISIKO

Ein einziges infiziertes Gerät kann das **gesamte Netzwerk kompromittieren**. Besonders kritisch: Mitarbeiter, die von zuhause arbeiten und ihr privates Gerät nutzen, auf dem kein Unternehmensvirenschutz läuft.

„Der Laptop, der über Home-Office auf den Server zugegriffen hat, hatte **seit 14 Monaten kein Virenschutz-Update** *bekommen."*

WAS DU DIESE WOCHE TUN KANNST

- ☐ Vollständige Liste aller Firmengeräte erstellen – auch Home-Office-Geräte
- ☐ Virenschutz-Status und letztes Update-Datum auf jedem Gerät prüfen
- ☐ Home-Office-Richtlinie für Gerätesicherheit schriftlich definieren
- ☐ Zentrales Endpoint-Management für automatische Updates prüfen

LÜCKE 07 · DATENSCHUTZRISIKO

Unverschlüsselte Kommunikation

07

DAS PROBLEM

E-Mails sind standardmäßig nicht verschlüsselt – sie sind eher wie Postkarten als wie versiegelte Briefe. Sensible Informationen wie Angebote, Verträge, Kundendaten oder Zugangsdaten werden täglich unverschlüsselt versendet.

DAS RISIKO

Unverschlüsselte Kommunikation kann abgefangen werden. **DSGVO-Verstöße durch unverschlüsselte Kundendaten** können Bußgelder in fünfstelliger Höhe nach sich ziehen – zusätzlich zum Reputationsschaden.

„Passwörter, Verträge und Kundendaten – **alles wurde jahrelang per unverschlüsselter E-Mail versendet.** *Keiner hat es hinterfragt."*

WAS DU DIESE WOCHE TUN KANNST

- ☐ TLS-Verschlüsselung für E-Mail-Server beim Provider aktivieren lassen
- ☐ WLAN auf WPA3 oder mindestens WPA2 umstellen
- ☐ Sicheren Messenger für interne Kommunikation einführen
- ☐ Regel definieren: Keine Passwörter oder Zugangsdaten per E-Mail versenden

LÜCKE 08 · INTERNES RISIKO

Keine Rechtetrennung im System

08

DAS PROBLEM

Haben alle Mitarbeiter Admin-Rechte auf ihrem Computer? Können alle auf alle Ordner und Daten im Netzwerk zugreifen? Fehlende Rechtevergabe ist eine der häufigsten und gefährlichsten Lücken – intern wie extern.

DAS RISIKO

Wenn ein Mitarbeiter auf Schadsoftware hereinfällt, hat diese **genau so viele Rechte wie der Mitarbeiter selbst**. Admin-Rechte bedeuten: die Schadsoftware kann alles installieren, löschen oder das gesamte Netzwerk verschlüsseln.

„Jeder Mitarbeiter hatte Admin-Rechte. Als einer auf einen Virus klickte, **konnte dieser das komplette Netzwerk verschlüsseln.**"

WAS DU DIESE WOCHE TUN KANNST

- ☐ Standard-Nutzerkonten ohne Admin-Rechte für alle Mitarbeiter einrichten
- ☐ Netzwerk-Ordner nach Abteilungen und Berechtigungen strukturieren
- ☐ Zugriffsprotokoll für sensible Datenbereiche aktivieren
- ☐ Regelmäßige Überprüfung der Rechtevergabe im Kalender verankern

LÜCKE 09 · OFT VERGESSEN

Kein Notfallplan bei IT-Ausfall

09

DAS PROBLEM

Was passiert, wenn euer Server morgen früh nicht startet? Wer wird angerufen? Welche Systeme sind kritisch? Wie lange kann euer Betrieb ohne IT arbeiten? Die meisten Betriebe haben keine dokumentierte Antwort darauf.

DAS RISIKO

Ohne Notfallplan verlieren Betriebe im Ernstfall durchschnittlich **2–3 zusätzliche Tage** durch Chaos und fehlende Kommunikation – zusätzlich zum eigentlichen Ausfall. Das kostet Umsatz, Kunden und Reputation.

„Jeder wusste, dass etwas Ernstes passiert war. **Niemand wusste, wer angerufen werden soll** *oder was als Erstes zu tun ist."*

WAS DU DIESE WOCHE TUN KANNST

- ☐ Einseitigen IT-Notfallplan erstellen und ausdrucken
- ☐ Notfallkontakte dokumentieren (IT-Dienstleister, Provider, Ansprechpartner)
- ☐ Kritische Systeme und deren Priorität bei Ausfall festlegen
- ☐ Notfallplan jährlich testen und aktualisieren

LÜCKE 10 · MENSCHLICHES EINFALLSTOR

Mitarbeiter, die auf alles klicken

10

DAS PROBLEM

Phishing ist die häufigste Angriffsmethode – und sie wird immer überzeugender. Gefälschte E-Mails von der Hausbank, dem Steuerberater oder dem Chef. Deine Mitarbeiter sind die letzte Verteidigungslinie. Und gleichzeitig die schwächste.

DAS RISIKO

Ein einziger Klick reicht, um das komplette Netzwerk zu infizieren. Laut BSI-Bericht beginnen **90 % aller erfolgreichen Cyberangriffe** auf Unternehmen mit einer Phishing-E-Mail.

„Die Phishing-E-Mail sah exakt so aus wie eine echte E-Mail der Sparkasse. Kein Mitarbeiter hätte den Unterschied erkannt."

WAS DU DIESE WOCHE TUN KANNST

- ☐ Phishing-Sensibilisierung im Team durchführen – echte Beispiele zeigen
- ☐ Regel definieren: Unbekannte Links nie direkt öffnen – im Zweifel anrufen
- ☐ Simulierten Phishing-Test durchführen (kostenlose Tools verfügbar)
- ☐ Klaren Meldeprozess für verdächtige E-Mails etablieren

DAS FAZIT

Was hast Du zu verlieren?



Lukas Blaschke
Inhaber · Blaschke IT, Haan

> *„Im besten Fall findest du heraus, dass deine IT perfekt aufgestellt ist. Das wäre schön.*
>
> *Aber in 9 von 10 Checks finden wir etwas, meistens etwas, das der Geschäftsführer nicht wusste und* **das alles kosten könnte.**
>
> *Bei unserem Security-Check zahlst du nichts. Du unterschreibst nichts. Du bekommst einen konkreten Report und entscheidest selbst was du damit machst."*

Was du bekommst – kostenlos:

- ✓ Kostenloses Vorabgespräch zur IT-Analyse
- ✓ Vollständiger Security-Scan deiner IT
- ✓ PDF-Report mit konkreten Handlungsempfehlungen
- ✓ Null Kosten · Null Bindung · Null Druck

Jetzt kostenlosen Security-Check sichern

anfrage.blaschke.cloud/security · Für Unternehmen ab 10 Mitarbeitern · Kein Vertrag

✓ Kein Vertrag ✓ Keine Kosten ✓ Kein Verkaufsgespräch ✓ DSGVO-konform ✓ Rechenzentrum in Deutschland